

Aula 3 (Módulo 17) — Persistência Avançada

Fechando o módulo com técnicas de persistência além das já vistas (Run keys, serviços, cron, tarefas agendadas, WMI Event Subscription) — mais furtivas, e por isso mais importantes de reconhecer.

1. DLL Hijacking / DLL Sideloadng

Já vimos que programas carregam DLLs (Módulo 11, Event ID 7). Muitos programas do Windows procuram DLLs em uma **ordem específica de pastas** — se um atacante conseguir colocar uma DLL **maliciosa com o mesmo nome** de uma DLL legítima em uma pasta que é verificada **antes** da pasta correta, o programa legítimo carrega (sem saber) o código malicioso na próxima vez que iniciar.

Por que é furtivo: a persistência não está num arquivo óbvio de malware — está "escondida" dentro da execução normal de um programa **legítimo e confiável**, todas as vezes que ele iniciar.

Evidência: Sysmon Event ID 7 (Image Loaded) mostrando uma DLL **não assinada**, carregada de uma pasta que não é a pasta padrão de instalação daquele programa, ou com um caminho levemente diferente do esperado (Módulo 11, Aula 2 já introduziu essa lógica de detecção).

2. COM Hijacking

O Windows usa um sistema chamado **COM** (*Component Object Model*) para que aplicações "conversem" entre si e reutilizem componentes — cada componente COM é identificado por um **CLSID** (um identificador único), registrado no Registry, apontando para o código que deve ser executado quando aquele componente é chamado.

A técnica: um atacante modifica essa entrada de Registry para apontar para **seu próprio código malicioso**, no lugar do componente legítimo. Toda vez que **qualquer** processo do sistema chamar aquele CLSID (o que acontece com bastante frequência para componentes comuns, muitas vezes automaticamente), o código malicioso executa.

Evidência: Sysmon Event ID 12/13 (Registry) mostrando modificação de chaves sob `HKCU\Software\Classes\CLSID\` ou `HKLM\Software\Classes\CLSID\` — o mesmo tipo de evento que já usamos para detectar Run keys (Módulo 11), só que observando um caminho diferente do Registry.

3. Accessibility Features (o "backdoor do Sticky Keys")

O Windows tem recursos de acessibilidade acionáveis **antes mesmo do login** (ex.: apertar Shift cinco vezes ativa o "Sticky Keys" — teclas de aderência). Esses recursos são, na verdade, **executáveis** normais (`sethc.exe` , entre outros) — um atacante com acesso administrativo prévio pode **substituir** esse executável por uma cópia do `cmd.exe` / `powershell.exe` , ganhando acesso a um shell **com privilégio de SYSTEM, mesmo sem fazer login**, simplesmente acionando aquele atalho na tela de login.

Por que é notável: é um dos exemplos mais claros de como persistência pode sobreviver e ser reativada mesmo **sem** nenhum usuário logado — só precisa de acesso físico ou remoto (RDP, Módulo 03) à tela de login.

Evidência: Sysmon Event ID 1 mostrando `winlogon.exe` (o processo responsável pela tela de login) como pai de `cmd.exe` / `powershell.exe` — uma relação pai/filho **extremamente** anômala (winlogon nunca deveria, normalmente,

abrir um shell). Também detectável verificando o hash do próprio `sethc.exe` /executáveis de acessibilidade contra o hash oficial esperado (mudança de hash = substituição).

4. Golden Ticket / Silver Ticket — prévia (aprofundamos no Módulo 19)

Técnicas de persistência **em nível de domínio** (Active Directory), abusando do protocolo de autenticação **Kerberos** — permitem que um atacante que já comprometeu certas credenciais críticas do domínio gere "tickets" de autenticação válidos por conta própria, sem precisar de senha, muitas vezes válidos por **anos**. Vamos aprofundar isso com o contexto necessário de Kerberos no Módulo 19 — mencionado aqui só para você já reconhecer que persistência "avançada" frequentemente mira a **identidade/autenticação**, não só "um arquivo que roda sempre".

5. Conectando tudo — o padrão por trás de toda persistência avançada

```
Run keys / serviços / cron / tarefas agendadas (já vistos)
  → persistência ÓBVIA, mais fácil de detectar (algo novo sendo criado)

DLL Hijacking / COM Hijacking / Accessibility Features (esta aula)
  → persistência DISFARÇADA dentro de comportamento/componentes
    JÁ EXISTENTES e confiáveis do sistema

Golden/Silver Ticket (prévia)
  → persistência na PRÓPRIA IDENTIDADE/autenticação, não em um
    arquivo/processo específico
```

A lição central: quanto mais avançada a técnica, mais ela tenta se **esconder dentro** de algo que já é confiável — o que reforça, mais uma vez, por que detecção baseada só em "isso é um arquivo novo/ desconhecido" não é suficiente. É preciso monitorar **mudanças de comportamento** em componentes já confiáveis (DLL carregada de local errado, CLSID reapontado, processo pai anômalo), não só a chegada de algo novo.

6. Exercício de reflexão

Para cada técnica desta aula, aplique a mesma pergunta central do Módulo 10: **quais das cinco dimensões de telemetria (process tree, command line, arquivo, registry, rede) revelariam essa técnica, e qual delas seria a mais reveladora em cada caso?**

7. Recapitulando o Módulo 17

- PowerShell ofensivo avançado (Aula 1): AMSI bypass, ofuscação além de Base64, download cradles — mas detecção comportamental (script já decodificado, rede/DNS) continua vencendo.
- Credential Dumping (Aula 2): LSASS/SAM/NTDS.dit como alvos; Event ID 10 (Process Access) como evidência central; Credential Guard e LSA Protection como mitigação mais forte.
- Persistência avançada (esta aula): DLL Hijacking, COM Hijacking e Accessibility Features escondem persistência dentro de componentes já confiáveis — exigindo detecção de **mudança de comportamento**, não só "algo novo

apareceu".

Módulo 17 concluído. 🎉

Próximo módulo

Módulo 18 — Web Security: HTTP/HTTPS, autenticação, APIs e as vulnerabilidades web mais relevantes — cada uma com o mesmo ciclo ataque → evidência → detecção → correção.

Fontes recomendadas

- **MITRE ATT&CK — T1574.001 (DLL Search Order Hijacking), T1546.015 (Component Object Model Hijacking), T1546.008 (Accessibility Features):** técnicas oficiais cobertas nesta aula.
<https://attack.mitre.org/techniques/T1574/001/>
- **MITRE ATT&CK — T1558 (Steal or Forge Kerberos Tickets):** técnica oficial relacionada a Golden/Silver Ticket, aprofundada no Módulo 19. <https://attack.mitre.org/techniques/T1558/>